Entra Identity Protection & Advanced Conditional Access

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Entra Identity Protection & Advanced Conditional Access 4
- What you get . . . 4
- What this delivers . . . 4
- The standard deployment model . . . 5
- Outcome . . . 5

1. Solution Overview — Entra Identity Protection & Advanced Conditional Access 5
- What this is . . . 5
- How it works . . . 5
- What you can control . . . 6
- Benefits . . . 6
- Limitations (be honest with buyers) . . . 6
- Auth / connections used . . . 7
- The standard deployment model . . . 7

2. Requirements Guide — Entra Identity Protection & Advanced Conditional Access 7
- 2.1 Entra ID P2 licensing (risk-based policies) . . . 7
- 2.2 A Conditional Access baseline already in place . . . 7
- 2.3 Break-glass exclusion group . . . 8
- 2.4 Legacy authentication blocked . . . 8
- 2.5 Strong authentication methods registered . . . 8
- 2.6 Pilot scope group . . . 8
- 2.7 Sign-in log export for KQL risk hunting (optional) . . . 9
- Checklist . . . 9

Global Requirements — Entra ID Solutions (category-level) 9
- G1. Microsoft Entra ID tenant . . . 9
- G2. Entra ID licensing (P1, P2 where noted) . . . 9
- G3. Administrative roles . . . 9
- G4. Break-glass (emergency access) accounts . . . 10
- G5. Healthy on-premises Active Directory . . . 10
- G6. An Entra Connect host server . . . 10
- G7. UPN / domain hygiene . . . 10
- G8. Network access to Microsoft cloud endpoints . . . 10

3. Implementation Guide — Entra Identity Protection & Advanced Conditional Access 11
- Naming convention (create/verify these exact names) . . . 11
- Step 1 — Assess and record the starting state . . . 11
- Step 2 — Create the pilot scope and confirm break-glass exclusion . . . 12

Step 3 — Create a named location and an authentication strength . . . 12
Step 4 — Create the authentication context and map a sensitive action . . . 12
Step 5 — Create the risk-based policies (Report-only) . . . 12
Step 6 — Create the step-up (authentication context) policy (Report-only) . . . 13
Step 7 — Create the token protection policy (Report-only) . . . 13
Step 8 — Pilot and read the report-only results . . . 13
Step 9 — Flip to enforcement in stages (staged rollout) . . . 13
Step 10 — Expand to production . . . 14
5. Testing Guide — Entra Identity Protection & Advanced Conditional Access 14
Test 1 — Identity Protection signal is flowing . . . 14
Test 2 — All four policies exist, report-only, break-glass excluded . . . 14
Test 3 — Sign-in risk policy would apply on a risky sign-in . . . 15
Test 4 — User risk policy would require password change . . . 15
Test 5 — Step-up on the sensitive context . . . 15
Test 6 — Token protection would apply on the supported client . . . 15
Test 7 — CAE revocation behaves . . . 15
Test 8 — Break-glass path is never blocked . . . 15
Test 9 — Enforcement matches the report-only prediction . . . 15
Pass/fail gate . . . 15
6. Troubleshooting Guide — Entra Identity Protection & Advanced Conditional Access 16
A. Risk signal / Identity Protection not showing . . . 16
B. Users unexpectedly blocked or challenged . . . 16
C. Break-glass / lockout risk . . . 17
D. Token protection issues . . . 17
E. CAE not revoking as expected . . . 17
F. Authentication strength problems . . . 17
G. Diagnostics quick reference . . . 18
H. When to escalate . . . 18
7. Best Practices — Entra Identity Protection & Advanced Conditional Access 18
Where to go next (adjacent catalog areas) . . . 19
8. Deliverables Summary — Entra Identity Protection & Advanced Conditional Access 19
Documentation . . . 19
PowerShell scripts (and KQL) . . . 20
What the buyer receives . . . 20
Outcome . . . 20
Appendix A — PowerShell Scripts 21

Executive Summary — Entra Identity Protection & Advanced Conditional Access

White-label · Entra ID Solutions

A static Conditional Access baseline cannot react to a compromise in progress. It decides once, at sign-in, on fixed conditions — it has no idea that a user's password just appeared on a leak list, that a session token was replayed from another country, or that an action about to happen is more sensitive than the sign-in that authorised it. This solution adds the layer a baseline is missing: the risk-and-context layer that turns your access decisions from a fixed gate into an adaptive perimeter.

It does two things together. First, it turns on **Microsoft Entra ID Protection** so the tenant has a live risk engine — risky users and risky sign-ins are detected, scored, and (once you enforce) challenged or blocked by risk-based Conditional Access. Second, it deploys **advanced Conditional Access**: authentication contexts for step-up on sensitive apps and actions, token protection (token binding) and Continuous Access Evaluation so stolen tokens stop working mid-session, authentication strengths to demand phishing-resistant methods where it matters, and named-location policy. Every policy is piloted **report-only first**, so you see exactly who each change would have affected before a single user is blocked.

This is a complete, deploy-it-today package written for an administrator with no prior identity-risk experience. It is deliberately the **risk/advanced layer** — it assumes you already have (or will add) a Conditional Access baseline (see the Conditional Access baseline solution) and does not re-teach that ground.

What you get

- A plain-language Solution Overview of Entra ID Protection (risk detections, risky users/sign-ins, risk-based policies) and advanced Conditional Access (authentication contexts, token protection, CAE, authentication strengths, named locations).
- A Requirements Guide with verify / implement-if-missing for every solution-specific prerequisite (P2 licensing flagged for you to verify).
- An Implementation Guide of precise, ordered steps in the Entra admin center — report-only first, then staged enforcement, with break-glass kept safe throughout.
- Five PowerShell scripts (Microsoft Graph / Az) plus KQL for risk discovery, pilot validation, a risk-and-coverage report, safe policy-state changes, and risk hunting.
- Testing and Troubleshooting guides for a confident rollout.

What this delivers

An adaptive identity perimeter: risky sign-ins and risky users are detected and (after validation) challenged with MFA or blocked; sensitive apps and actions demand a fresh, phishing-resistant step-up via authentication context; tokens are bound to their device and revoked in near-real-time by Continuous Access Evaluation; and every one of these controls is proven in report-only mode against real traffic before it enforces. Break-glass emergency accounts are excluded from every risk and enforcement policy so a misconfiguration can never lock all administrators out.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Access decisions that react to risk in real time — risk-based challenges, step-up on sensitive actions, and token protection layered over your Conditional Access baseline — proven on a pilot in report-only before you enforce.

1. Solution Overview — Entra Identity Protection & Advanced Conditional Access

What this is

This solution is the **risk and advanced layer** that sits on top of a Conditional Access baseline. It combines two Microsoft Entra capabilities:

- **Microsoft Entra ID Protection** — a risk engine that continuously evaluates sign-ins and user accounts for signs of compromise (leaked credentials, impossible travel, anonymous IP, token replay, and more), assigns a risk level, and lets Conditional Access act on that risk.
- **Advanced Conditional Access** — the parts of Conditional Access beyond a static "require MFA" baseline: authentication contexts (step-up on a per-app or per-action basis), token protection (binding a session token to the device that obtained it), Continuous Access Evaluation (near real-time revocation), authentication strengths (demand a specific method such as phishing-resistant FIDO2), and named locations.

Together they turn a fixed access gate into an adaptive perimeter that reacts to risk as it emerges.

This is **distinct from the Conditional Access baseline** (require-MFA, block-legacy-auth, device-compliance — covered by the Conditional Access baseline solution). This solution assumes that baseline exists and adds the risk/context controls on top. It also absorbs and replaces the older "Zero Trust for Identity" framing: the controls here are the identity core of a Zero Trust program.

How it works

1. **Entra ID Protection** ingests signals from every sign-in and computes two scores: a **sign-in risk** (is *this* sign-in suspicious?) and a **user risk** (is *this account* likely compromised?). Detections range from real-time (impossible travel, anonymous IP) to offline (leaked credentials, threat-intelligence).

2. A **risk-based Conditional Access policy** uses those scores as a condition. For example: if sign-in risk is *medium or high*, require multi-factor authentication; if user risk is *high*, require a secure password change. Low-risk sign-ins pass through untouched.

3. An **authentication context** is a label (for example `c1`) you attach to a sensitive application or a sensitive action inside an app (such as a privileged operation). A Conditional Access policy then targets that label and demands a step-up — a fresh MFA, or a specific authentication strength — only when the

sensitive context is invoked, not on every sign-in.

4. **Token protection** binds the refresh/session token to the client device's cryptographic key, so a token stolen and replayed from a different device is rejected. **Continuous Access Evaluation (CAE)** lets resource providers (Exchange Online, SharePoint, Graph) revoke or re-challenge a live session within minutes of a critical event (disabled account, password reset, elevated risk) instead of waiting up to an hour for the token to expire.

5. **Authentication strengths** let a policy require a *specific* method — for example phishing-resistant MFA (FIDO2 security key, passkey, Windows Hello for Business, certificate) — rather than "any MFA". Named locations define trusted or blocked IP ranges and countries that policies reference.

6. **Report-only mode** evaluates every new policy against real sign-ins and records "would have applied / would have blocked" in the sign-in logs **without affecting the user**. You read that data, confirm the blast radius, then move the policy to On.

7. **Break-glass emergency accounts** are excluded from all risk and enforcement policies, so a misconfigured risk policy or a bad enforcement flip can never lock every administrator out.

What you can control

• Which risk levels trigger action, and what action (block, require MFA, require secure password change), for both sign-in risk and user risk policies.

• Authentication-context labels and which apps/actions map to them; the step-up each context demands.

• Token protection enforcement (via Conditional Access session controls) and the scope it applies to.

• Authentication strengths — built-in (phishing-resistant MFA, passwordless MFA, MFA) or a custom combination — and which policy/context requires each.

• Named locations (IP ranges, countries) marked trusted or used to block.

• Report-only vs enabled state for every policy, and the pilot scope each targets, plus break-glass exclusions.

Benefits

• Adaptive — access reacts to real-time and offline risk instead of deciding once on fixed conditions.

• Step-up only where it matters — sensitive apps/actions demand a fresh, strong proof without adding friction to routine sign-ins.

• Token theft resistance — token protection and CAE make stolen tokens far less useful and revoke sessions in near real time.

• Phishing-resistant where required — authentication strengths let you demand FIDO2/passkey for the highest-value access.

• Safe to roll out — report-only first shows the exact blast radius before anything enforces.

Limitations (be honest with buyers)

• **Entra ID P2** is required for risk-based Conditional Access and the full risky-users/risky-sign-ins experience (P1 sees limited risk data). *Verify current licensing availability in your tenant.*

• **Token protection** and some **authentication-context** and **CAE** behaviours have platform, client, and preview constraints (for example token protection currently targets specific Windows sign-in scenarios and clients). *Verify current availability and supported clients in your tenant before enforcing.*

• Risk-based policies act on Microsoft's risk scoring; tuning (dismissing false positives, confirming compromise) is an ongoing operational task, not a one-time setup.

• This layer governs Entra sign-in and session risk; it does not replace endpoint protection, a Conditional Access baseline, or PIM — it complements them.

Auth / connections used

• Interactive administration in the Entra admin center (`https://entra.microsoft.com`).

• The included scripts use the **Microsoft Graph PowerShell SDK** (read-only scopes for discovery/validation/report; a scoped read-write policy scope only for the gated policy-state change script) and optionally **Az** / a Log Analytics workspace for KQL risk hunting when sign-in logs are exported to Microsoft Sentinel or Log Analytics.

The standard deployment model

> *Assess current risk posture and CA baseline -> Configure Identity Protection risk policies, authentication contexts, token protection, authentication strengths, and named locations in report-only -> Pilot against a small scope -> Validate report-only results and flip to enforce in stages -> Expand to the tenant. Break-glass accounts stay excluded throughout. pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

2. Requirements Guide — Entra Identity Protection & Advanced Conditional Access

Verify every requirement before configuring. Each entry: Description · Why · Verify · Implement-if-missing. Category-wide prerequisites (tenant, base licensing, admin roles, break-glass accounts, network) are in `global-requirements-entra-id-solutions.md` — do not repeat them here; confirm them first.

2.1 Entra ID P2 licensing (risk-based policies)

Description: Microsoft Entra ID P2 for the users who will be covered by risk-based Conditional Access and seen in risky users/sign-ins. Why: Risk-based Conditional Access, the full risky-users/risky-sign-ins reports, and risk remediation are P2 features; with only P1 you get limited risk signal and cannot use risk as a policy condition. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P2 (often bundled in EMS E5 / M365 E5). In Entra -> `Protection -> Identity Protection`, confirm the risky users/sign-ins reports show data. *Verify current licensing availability in your tenant.* Implement: Assign Entra ID P2 (or a bundle that includes it) to the in-scope users, then run `ENTIDP-Discovery.ps1`.

2.2 A Conditional Access baseline already in place

Description: An existing Conditional Access baseline (require MFA for admins/users, block legacy authentication, require compliant/hybrid-joined device where used). Why: This solution is the risk/advanced *layer* — it assumes the baseline exists. Risk-based and step-up policies complement the baseline; they do not replace require-MFA or block-legacy-auth. Verify: Entra -> `Protection -> Conditional Access -> Policies`; confirm baseline policies exist and are On; run `ENTIDP-Discovery.ps1` to inventory them. Implement: Deploy the Conditional Access baseline first (see the Conditional Access baseline solution / "where to go next" in Best Practices), then return here.

2.3 Break-glass exclusion group

Description: A security group containing your two cloud-only break-glass accounts, excluded from every risk and enforcement policy created here. Why: A misconfigured risk policy or a premature enforcement flip could otherwise lock out all administrators; break-glass accounts must always retain a path in. Verify: Entra -> `Groups`; confirm a group (for example `CA Break-Glass Exclusion`) contains both break-glass accounts; confirm it is on the Exclude list of your baseline policies; run `ENTIDP-Discovery.ps1`. Implement: Create `CA Break-Glass Exclusion`, add both cloud-only break-glass accounts, and add it to the Exclude tab of every policy in this solution.

2.4 Legacy authentication blocked

Description: Legacy/basic authentication protocols blocked by Conditional Access (part of the baseline). Why: Legacy authentication bypasses modern controls including risk evaluation, token protection, and CAE; leaving it open undermines every control in this solution. Verify: Entra -> `Protection -> Conditional Access`; confirm a policy blocks legacy authentication; check `Sign-in logs` for legacy-auth sign-ins; run `ENTIDP-Report.ps1`. Implement: Add/confirm a Conditional Access policy blocking legacy authentication for all users (with break-glass excluded) before enforcing risk policies.

2.5 Strong authentication methods registered

Description: In-scope users (especially pilot users) have modern MFA registered; for authentication-strength policies, phishing-resistant methods (FIDO2 security key, passkey, Windows Hello for Business, or certificate) are available. Why: A risk-based challenge or a step-up that demands a method the user has not registered will block them; phishing-resistant strengths require the corresponding method to exist. Verify: Entra -> `Protection -> Authentication methods -> Activity` (registration report); run `ENTIDP-Report.ps1`. Implement: Drive MFA/passwordless registration first (see the passwordless / passkey solutions); for phishing-resistant strengths, enable and register FIDO2/passkey/WHfB for pilot users.

2.6 Pilot scope group

Description: A small security group of representative users to validate risk policies, step-up, token protection, and strengths before tenant-wide rollout. Why: The identity plane is high risk; a report-only pilot proves the blast radius and the user experience before enforcement expands. Verify: Entra -> `Groups`; confirm the pilot group exists; run `ENTIDP-Validate.ps1`. Implement: Create `IDP Pilot – Risk Scope – Pilot` and add a few representative users (include at least one non-admin and one admin who is *not* break-glass).

2.7 Sign-in log export for KQL risk hunting (optional)

Description: Entra sign-in and risk logs exported to a Log Analytics workspace / Microsoft Sentinel, if you want to run the included KQL risk-hunting queries. Why: `ENTIDP-RiskHunt.ps1` runs KQL against exported sign-in/risk logs for trend and hunting queries; without export, use the Graph-based fallback in the same script and the Identity Protection portal. Verify: Entra -> `Identity -> Monitoring & health -> Diagnostic settings`; confirm `SignInLogs`, `RiskyUsers`, and `UserRiskEvents` are exported to a workspace. *Verify current diagnostic category availability in your tenant.* Implement: Add a diagnostic setting exporting the sign-in and risk log categories to a Log Analytics workspace (Sentinel-enabled if you use Sentinel).

Checklist

- Entra ID P2 assigned to in-scope users — `ENTIDP-Discovery.ps1` *(verify availability)*
- Conditional Access baseline in place and On
- `CA Break-Glass Exclusion` group contains both break-glass accounts
- Legacy authentication blocked — `ENTIDP-Report.ps1`
- Modern / phishing-resistant methods registered for pilot users — `ENTIDP-Report.ps1`
- `IDP Pilot – Risk Scope – Pilot` group created — `ENTIDP-Validate.ps1`
- (Optional) Sign-in/risk logs exported for KQL — `ENTIDP-RiskHunt.ps1`

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Entra Identity Protection & Advanced Conditional Access

Follow these steps in order, in the Microsoft Entra admin center (`https://entra.microsoft.com`), mainly under `Protection`. Every new policy is created in **Report-only** mode first; you enforce only after the Testing Guide passes. Break-glass accounts (via the `CA Break-Glass Exclusion` group) are excluded from every policy in this guide.

> *Model: configure the risk engine and advanced controls in report-only, pilot against a small scope, validate the report-only results against real traffic, then flip to enforce in stages, then expand. Every object you create uses the convention `<Purpose> – <Scope> – <Stage>` and is reused by name in Testing and Troubleshooting.*

Naming convention (create/verify these exact names)

Object	Name
Pilot scope group	`IDP Pilot – Risk Scope – Pilot`
Break-glass exclusion group	`CA Break-Glass Exclusion`
Named location	`Named Location – Trusted Egress – Pilot`
Authentication strength	`Auth Strength – Phishing-Resistant – Pilot`
Authentication context	`Auth Context c1 – Sensitive Actions – Pilot`
Sign-in risk policy	`CA – Sign-In Risk – Pilot (Report-Only)`
User risk policy	`CA – User Risk – Pilot (Report-Only)`
Step-up (context) policy	`CA – Step-Up Sensitive Apps – Pilot (Report-Only)`
Token protection policy	`CA – Token Protection – Pilot (Report-Only)`

Step 1 — Assess and record the starting state

1. Run `ENTIDP-Discovery.ps1` to inventory current Conditional Access policies, Identity Protection availability, named locations, authentication strengths, and authentication contexts. Keep the output as your before-state.

2. Entra -> `Protection -> Identity Protection`; confirm the `Risky users`, `Risky sign-ins`, and `Risk detections` reports show data (confirms P2 signal is flowing). *Verify P2 licensing if the reports are empty.*

3. Confirm your Conditional Access baseline is On and that `CA Break-Glass Exclusion` exists and is excluded from the baseline. Do not proceed until break-glass exclusion is confirmed.

Step 2 — Create the pilot scope and confirm break-glass exclusion

1. Entra -> `Groups -> New group` -> Security -> name `IDP Pilot – Risk Scope – Pilot`; add a few representative users (at least one non-admin and one admin who is not break-glass). Create.

2. Confirm `CA Break-Glass Exclusion` contains both cloud-only break-glass accounts. You will add this group to the Exclude tab of every policy below.

Step 3 — Create a named location and an authentication strength

1. Entra -> `Protection -> Conditional Access -> Named locations -> + Countries location` or `+ IP ranges location`; create `Named Location – Trusted Egress – Pilot` with your organisation's known-good egress IP ranges. Mark as trusted only if you are confident in the ranges. Save.

2. Entra -> `Protection -> Authentication methods -> Authentication strengths -> + New authentication strength`; name it `Auth Strength – Phishing-Resistant – Pilot`; select phishing-resistant methods (FIDO2 security key, passkey, Windows Hello for Business, certificate-based). Save. *Verify the methods you select are registered for your pilot users (Requirement 2.5).*

Step 4 — Create the authentication context and map a sensitive action

1. Entra -> `Protection -> Conditional Access -> Authentication context -> + New authentication context`; name it `Auth Context c1 – Sensitive Actions – Pilot`; tick "Publish to apps"; save (it takes an ID such as `c1`).

2. Map the context to something sensitive: for a sensitive app, you will reference the context in the step-up policy (Step 6). To protect a sensitive *action*, map the context where the action is defined — for example PIM role activation (`Identity governance -> PIM -> Roles -> Settings -> require authentication context on activation`) or a sensitive SharePoint site. *Verify current authentication-context integration points for your target service.*

Step 5 — Create the risk-based policies (Report-only)

1. Entra -> `Protection -> Conditional Access -> Policies -> + New policy`; name `CA – Sign-In Risk – Pilot (Report-Only)`.

• Assignments -> Users: include `IDP Pilot – Risk Scope – Pilot`; exclude `CA Break-Glass Exclusion`.

• Target resources: All cloud apps.

• Conditions -> Sign-in risk: select `High` and `Medium`.

• Grant: Require multi-factor authentication (optionally require `Auth Strength – Phishing-Resistant – Pilot`).

• Enable policy: **Report-only**. Create.

1. `+ New policy`; name `CA – User Risk – Pilot (Report-Only)`.

• Users: include the pilot group; exclude `CA Break-Glass Exclusion`.

• Target resources: All cloud apps.

• Conditions -> User risk: select `High`.

• Grant: Require multi-factor authentication AND Require password change.

• Enable policy: **Report-only**. Create.

Step 6 — Create the step-up (authentication context) policy (Report-only)

1. `+ New policy`; name `CA – Step-Up Sensitive Apps – Pilot (Report-Only)`.

• Users: include the pilot group; exclude `CA Break-Glass Exclusion`.

• Target resources: change the selector to `Authentication context` and select `Auth Context c1 – Sensitive Actions – Pilot`.

• Grant: Require authentication strength -> `Auth Strength – Phishing-Resistant – Pilot` (or Require MFA if you are not ready for phishing-resistant).

• Enable policy: **Report-only**. Create.

Step 7 — Create the token protection policy (Report-only)

1. `+ New policy`; name `CA – Token Protection – Pilot (Report-Only)`.

• Users: include the pilot group; exclude `CA Break-Glass Exclusion`.

• Target resources: select the supported workloads (for example Office 365 / Exchange Online and SharePoint Online) — *verify current token-protection-supported apps and clients in your tenant.*

• Conditions -> Client apps / Device platforms: restrict to the supported scenario (currently specific Windows sign-in scenarios).

• Session: tick **Require token protection for sign-in sessions**.

• Enable policy: **Report-only**. Create.

1. Confirm Continuous Access Evaluation is enabled (it is on by default for supported services). You do not create a separate CAE policy; it is honoured by supported resource providers. Verify with `ENTIDP-Validate.ps1`.

Step 8 — Pilot and read the report-only results

1. Have pilot users sign in and exercise the sensitive app/action, and (where safe) simulate a risky sign-in condition. Run `ENTIDP-Validate.ps1` to confirm all four policies exist, are report-only, and exclude break-glass.

2. Entra -> `Sign-in logs`; open a pilot sign-in -> `Report-only` tab; confirm each policy shows "Would apply" / "Would block" as intended and that **no break-glass account** shows an apply. Run `ENTIDP-Report.ps1` for the aggregate risk-and-coverage picture.

3. This is the pass/fail gate. Do not enforce until the report-only results match intent (see Testing Guide).

Step 9 — Flip to enforcement in stages (staged rollout)

1. Enforce the least-disruptive policy first. In each policy, set `Enable policy` to **On**, or use `ENTIDP-Set-PolicyState.ps1` (default `-WhatIf` preview) to flip a named policy from report-only to enabled after review. Recommended order: sign-in risk -> user risk -> step-up -> token protection.

2. After each flip, watch `Sign-in logs` (now the real `Conditional Access` tab, not report-only) and the risky-sign-ins report for unexpected blocks; keep a break-glass account ready. Rename each policy by dropping the `(Report-Only)` suffix once enforced (for example `CA – Sign-In Risk – Pilot`).

3. If a flip causes unexpected blocks, set the policy back to Report-only immediately (or re-run `ENTIDP-Set-PolicyState.ps1` to revert) and investigate.

Step 10 — Expand to production

1. Broaden each policy's Users assignment from `IDP Pilot – Risk Scope – Pilot` to All users (keeping `CA Break-Glass Exclusion` on the Exclude tab), re-validating in report-only for the wider scope before enforcing.

2. Extend token protection and step-up to additional supported apps/actions as their prerequisites are met.

3. Stand up the ongoing risk operations loop: triage risky users/sign-ins, dismiss false positives, confirm compromises, and run `ENTIDP-RiskHunt.ps1` (KQL or Graph fallback) on a schedule.

Order of operations

```
Assess/discovery -> Pilot + break-glass exclusion -> Named location + auth strength -> Auth context -> Risk policies (report-only) -> Step-up policy (report-only) -> Token protection (report-only) -> Read report-only results -> Staged enforce -> Expand
```

5. Testing Guide — Entra Identity Protection & Advanced Conditional Access

Run after the pilot policies are configured in report-only (Implementation Step 8), again after each enforcement flip (Step 9), and after each expansion. Use `ENTIDP-Validate.ps1` for configuration state and `ENTIDP-Report.ps1` for the risk-and-coverage picture.

Test 1 — Identity Protection signal is flowing

Do: Entra -> `Protection -> Identity Protection -> Risky sign-ins` / `Risky users`; or run `ENTIDP-Report.ps1`. Expected: The reports show detections/scoring (confirming P2 signal). If empty, verify P2 licensing before continuing.

Test 2 — All four policies exist, report-only, break-glass excluded

Do: Run `ENTIDP-Validate.ps1`. Expected: `CA – Sign-In Risk – Pilot (Report-Only)`, `CA – User Risk – Pilot (Report-Only)`, `CA – Step-Up Sensitive Apps – Pilot (Report-Only)`, and `CA – Token Protection – Pilot (Report-Only)` all exist, are in

report-only, target the pilot group, and exclude `CA Break-Glass Exclusion`.

Test 3 — Sign-in risk policy would apply on a risky sign-in

Do: With a pilot (non-break-glass) user, trigger or await a medium/high sign-in-risk event; open the sign-in in `Sign-in logs -> Report-only`. Expected: `CA – Sign-In Risk – Pilot (Report-Only)` shows "Would apply" and would require MFA; a low-risk sign-in shows the policy not applied.

Test 4 — User risk policy would require password change

Do: For a pilot user flagged high user-risk (or a confirmed-compromised test account), review the report-only result. Expected: `CA – User Risk – Pilot (Report-Only)` would require MFA and a secure password change; break-glass accounts never show an apply.

Test 5 — Step-up on the sensitive context

Do: A pilot user invokes the sensitive app/action mapped to `Auth Context c1 – Sensitive Actions – Pilot` (for example PIM activation or the sensitive app). Expected: `CA – Step-Up Sensitive Apps – Pilot (Report-Only)` would require the phishing-resistant authentication strength; routine sign-ins to non-sensitive apps are unaffected.

Test 6 — Token protection would apply on the supported client

Do: A pilot user signs in from the supported Windows scenario/client; review the report-only result and run `ENTIDP-Validate.ps1`. Expected: `CA – Token Protection – Pilot (Report-Only)` would require token protection for the supported workload; unsupported clients are not blocked (they fall outside the policy scope). *Verify current supported clients.*

Test 7 — CAE revocation behaves

Do: In a controlled test, disable a pilot test account (or reset its password) while it holds a live session to a CAE-supported service (Exchange/SharePoint/Graph). Expected: The session is challenged/revoked in near real time (minutes), not after the full token lifetime.

Test 8 — Break-glass path is never blocked

Do: Confirm (report-only and after enforcement) that a break-glass account can sign in with no risk/step-up/token policy applying; run `ENTIDP-Validate.ps1`. Expected: Break-glass accounts are excluded from all four policies and retain an unobstructed path in.

Test 9 — Enforcement matches the report-only prediction

Do: After flipping a policy to On (Step 9), repeat the relevant test above against the real `Conditional Access` result (not report-only). Expected: The enforced behaviour matches what report-only predicted; no unexpected user population is blocked.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1-6 and Test 8 pass in report-only; report-only results match intent; break-glass excluded
Enforce pass	Test 9 passes for each policy as it is flipped, in the recommended order, with no unexpected blocks
Expand pass	Tests re-pass at the wider scope in report-only before enforcing tenant-wide

6. Troubleshooting Guide — Entra Identity Protection & Advanced Conditional Access

Use `ENTIDP-Validate.ps1` / `ENTIDP-Discovery.ps1` for current configuration state, `ENTIDP-Report.ps1` for the risk-and-coverage picture, and `ENTIDP-Set-PolicyState.ps1` (default `-WhatIf`) to flip a policy back to report-only fast.

A. Risk signal / Identity Protection not showing

Symptom	Cause	Remediation
Risky users/sign-ins reports empty	Entra ID P2 not assigned to in-scope users	Assign P2 to in-scope users; wait for signal; run `ENTIDP-Report.ps1`. *Verify P2 availability.*
Risk condition greyed out in a CA policy	No P2, or the policy uses an unsupported combination	Confirm P2; ensure the policy targets users/apps that support the risk condition
No detections ever appear	Traffic genuinely low-risk, or legacy auth bypassing evaluation	Confirm legacy auth is blocked (`ENTIDP-Report.ps1`); risk detections are event-driven, not guaranteed

B. Users unexpectedly blocked or challenged

Symptom	Cause	Remediation
Pilot users blocked after an enforcement flip	Policy moved to On before report-only was clean, or a required method not registered	Set the policy back to report-only (`ENTIDP-Set-PolicyState.ps1`); confirm the required method is registered (`ENTIDP-Report.ps1`); re-read report-only before re-enforcing
Risk-based MFA loops	User has no strong method, or user-risk password change not completed	Register MFA; complete the secure password change to clear user risk

Symptom	Cause	Remediation
Step-up prompts on every sign-in	Authentication context mapped too broadly, or context applied at app level unintentionally	Narrow the context to the specific sensitive app/action; confirm `CA – Step-Up Sensitive Apps – Pilot` targets the context, not all apps

C. Break-glass / lockout risk

- Confirm `CA Break-Glass Exclusion` (both cloud-only break-glass accounts) is on the Exclude tab of all four policies; run `ENTIDP-Validate.ps1`.
- If a risk or enforcement change locks out administrators, sign in with a break-glass account, set the offending policy to report-only, and investigate. Never add break-glass accounts to a risk or enforcement policy.

D. Token protection issues

Symptom	Cause	Remediation
Token protection "would block" supported users unexpectedly	Policy scope includes unsupported clients/platforms	Restrict the policy to the supported Windows scenario/clients; *verify current supported clients*
Token protection never applies	Targeting an unsupported app, or client not in the supported scenario	Target a supported workload (for example Exchange/SharePoint); confirm client support with `ENTIDP-Validate.ps1`
Preview-related inconsistency	Feature or scenario still in preview	Verify current availability in your tenant; keep the policy report-only until preview status is confirmed

E. CAE not revoking as expected

- CAE revocation is honoured by supported resource providers (Exchange Online, SharePoint Online, Graph) and takes minutes, not seconds. If a session persists, confirm the app/client is CAE-capable and that CAE is not disabled by a "customize continuous access evaluation" session control.
- Legacy-auth or non-CAE clients do not honour CAE — confirm legacy auth is blocked.

F. Authentication strength problems

Symptom	Cause	Remediation
Strength policy blocks users who "have MFA"	Strength requires a specific (phishing-resistant) method they have not registered	Register FIDO2/passkey/WHfB for those users, or relax the strength to standard MFA for now

Symptom	Cause	Remediation
Custom strength not selectable	Method not enabled tenant-wide in Authentication methods	Enable the method in `Authentication methods -> Policies` first

G. Diagnostics quick reference

```
Connect-MgGraph -Scopes 'Policy.Read.All','IdentityRiskyUser.Read.All','IdentityRiskEvent.Read.All'
# Conditional Access policies and their state
Get-MgIdentityConditionalAccessPolicy -All | Select-Object DisplayName, State
# Risky users / risk detections
Invoke-MgGraphRequest -Method GET -Uri '/v1.0/identityProtection/riskyUsers?$top=20'
Invoke-MgGraphRequest -Method GET -Uri '/v1.0/identityProtection/riskDetections?$top=20'
# Authentication strengths and named locations
Invoke-MgGraphRequest -Method GET -Uri '/v1.0/policies/authenticationStrengthPolicies'
Invoke-MgGraphRequest -Method GET -Uri '/v1.0/identity/conditionalAccess/namedLocations'
```

H. When to escalate

If P2 is assigned, break-glass is excluded, required methods are registered, and a policy still misbehaves after a clean report-only read, capture `ENTIDP-Report.ps1` output and the affected sign-in's report-only detail and open a Microsoft support case.

7. Best Practices — Entra Identity Protection & Advanced Conditional Access

- Always start report-only. Every risk, step-up, and token-protection policy goes to production through report-only first. Read the "would apply / would block" data in the sign-in logs and confirm the blast radius before you set a policy On.
- Keep break-glass out of every policy. Exclude `CA Break-Glass Exclusion` from all four policies, always. A risk policy or a bad enforcement flip must never be able to lock out every administrator. Protect break-glass accounts with strong stored credentials and sign-in alerts.
- Enforce in stages, least-disruptive first. Flip sign-in risk, then user risk, then step-up, then token protection — one at a time, watching the logs after each, so a problem is isolated to one change.
- Tune the risk engine, do not just enable it. Triage risky users and risky sign-ins routinely: dismiss false positives, confirm real compromises, and let confirmations improve Microsoft's scoring. Risk policy is an operating loop, not a switch.
- Step up only where it matters. Use authentication contexts so sensitive apps and actions demand a fresh, strong proof, while routine sign-ins stay low-friction. Over-broad step-up trains users to click through prompts.
- Demand phishing-resistant where the value justifies it. Use authentication strengths to require FIDO2/passkey/WHfB on the highest-value access, but confirm those methods are registered first so you do not lock users out.
- Respect the token-protection and CAE constraints. These have platform, client, and preview limits — scope policies to the supported clients and verify current availability in your tenant before enforcing, so

unsupported clients are not caught unexpectedly.

• Name every object consistently. Use `<Purpose> – <Scope> – <Stage>` for groups, contexts, strengths, and policies so audits, rollbacks, and expansion stay repeatable. Drop the `(Report-Only)` suffix only when a policy is actually enforced.

• Keep a rollback path. Know how to set any policy back to report-only instantly (`ENTIDP-Set-PolicyState.ps1` reverts by name); keep the before-state from `ENTIDP-Discovery.ps1`.

• Verify licensing and preview facts. P2 is required for risk-based policies; token protection and some contexts/CAE behaviours may be in preview or client-limited — verify current availability in your tenant rather than assuming.

Where to go next (adjacent catalog areas)

• **Conditional Access baseline** — the require-MFA / block-legacy-auth / device-compliance foundation this layer sits on. If you do not have it, deploy it first.

• **Privileged Identity Management (PIM)** — make admin roles just-in-time and require the authentication context defined here on activation.

• **Privileged Access Workstation (PAW) for Cloud Administration** — pair risk/step-up with a clean, hardened admin device required by Conditional Access device filters.

• **Passwordless / passkey (FIDO2) rollout** — register the phishing-resistant methods your authentication strengths demand.

• **Enterprise app & service-principal governance**, **Hybrid identity (Entra Connect)**, and **Entra ID Governance** — the surrounding identity program this risk layer protects.

8. Deliverables Summary — Entra Identity Protection & Advanced Conditional Access

Documentation

Document	Purpose
Executive Summary	Business case and what is in the box
1. Solution Overview	What Identity Protection + advanced Conditional Access are; how risk, contexts, token protection, CAE, and strengths work; benefits and limitations
2. Requirements Guide	Solution-specific prerequisites with Verify / Implement-if-missing (P2 flagged to verify)
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Entra steps — report-only first, staged enforcement, break-glass excluded
5. Testing Guide	Validation procedures with pass/fail gates

Document	Purpose
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations and where to go next

PowerShell scripts (and KQL)

Script	What it does
`ENTIDP-Discovery.ps1`	Read-only inventory of Conditional Access policies, Identity Protection availability, named locations, authentication strengths, and authentication contexts (Microsoft Graph)
`ENTIDP-Validate.ps1`	Confirms the four pilot policies exist, are report-only, target the pilot scope, and exclude break-glass; checks CAE/token-protection prerequisites
`ENTIDP-Report.ps1`	Risk-and-coverage report — risky users/sign-ins summary, risk-policy coverage, legacy-auth and registration gaps (Microsoft Graph)
`ENTIDP-Set-PolicyState.ps1`	Safe change script (default `-WhatIf`); flips a named Conditional Access policy between report-only and enabled for staged enforcement/rollback; never touches break-glass exclusions
`ENTIDP-RiskHunt.ps1`	Risk hunting via KQL against exported sign-in/risk logs (Log Analytics / Sentinel) with a Graph-based fallback when no workspace is available

What the buyer receives

- This implementation guide as a branded Word document and PDF.
- All five PowerShell scripts (with embedded KQL) in a single ZIP.
- Delivered as a Complete Solution Package (PDF + Word + scripts).
- A repeatable process following the standard model: Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

An adaptive identity perimeter that reacts to risk in real time — risk-based challenges, step-up on sensitive actions, token protection, and CAE layered over your Conditional Access baseline — proven on a pilot in report-only before you enforce.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTIDP-Discovery.ps1

Purpose: Records the current advanced-access posture before any change: all Conditional Access policies and their state (report-only / enabled / disabled), whether Identity Protection risk signal is available, named locations, authentication strengths, and authentication contexts. This is the before-state you keep for rollback. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTIDP-Discovery.ps1 Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, IdentityRiskyUser.Read.All, IdentityRiskEvent.Read.All. EXPECTED RESULTS A printed inventory: CA policy names + state, count of risky users/detections (P2 signal), named locations, authentication strengths, and authentication contexts. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Entra ID P2 availability. > [CmdletBinding()] param() if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','IdentityRiskyUser.Read.All','IdentityRiskEvent.Read.All' -NoWelcome

How to run: powershell -ExecutionPolicy Bypass -File .\ENTIDP-Discovery.ps1 Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, IdentityRiskyUser.Read.All, IdentityRiskEvent.Read.All. EXPECTED RESULTS A printed inventory: CA policy names + state, count of risky users/detections (P2 signal), named locations, authentication strengths, and authentication contexts. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Entra ID P2 availability. > [CmdletBinding()] param() if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','IdentityRiskyUser.Read.All','IdentityRiskEvent.Read.All' -NoWelcome

ENTIDP-Report.ps1

Purpose: Produces a management-readable snapshot: counts of risky users by level and recent risk detections, which Conditional Access policies use a risk condition (risk coverage), whether a legacy-authentication block exists, and MFA/phishing-resistant registration coverage. Highlights gaps that should close before or during enforcement. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTIDP-Report.ps1 Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, IdentityRiskyUser.Read.All, IdentityRiskEvent.Read.All, AuditLog.Read.All, UserAuthenticationMethod.Read.All. EXPECTED RESULTS A printed report of risk posture and coverage gaps. Use it as the pilot pass/fail evidence and the ongoing risk-operations dashboard. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Entra ID P2 availability. > [CmdletBinding()] param() if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','IdentityRiskyUser.Read.All','IdentityRiskEvent.Read.All','AuditLog.Read.All','UserAuthenticationMethod.Read.All' -NoWelcome Write-Host "`n=== ENTIDP — risk & coverage report ===" -ForegroundColor Cyan

How to run: powershell -ExecutionPolicy Bypass -File .\ENTIDP-Report.ps1 Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, IdentityRiskyUser.Read.All, IdentityRiskEvent.Read.All, AuditLog.Read.All, UserAuthenticationMethod.Read.All. EXPECTED

RESULTS A printed report of risk posture and coverage gaps. Use it as the pilot pass/fail evidence and the ongoing risk-operations dashboard. .NOTES White-label — Entra ID Solutions. Read-only against Graph. Verify Entra ID P2 availability. > [CmdletBinding()] param() if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','IdentityRiskyUser.Read.All','IdentityRiskEvent.Read.All','AuditLog.Read.All','UserAuthenticationMethod.Read.All' -NoWelcome Write-Host "`n=== ENTIDP — risk & coverage report ===" -ForegroundColor Cyan

ENTIDP-RiskHunt.ps1

Purpose: Runs the ongoing risk-operations hunt. If Entra sign-in and risk logs are exported to a Log Analytics / Microsoft Sentinel workspace, it runs the embedded KQL queries there. If no workspace is provided, it falls back to a read-only Microsoft Graph query of recent risk detections and risky sign-ins so the hunt still works without a workspace. HOW TO RUN KQL mode: powershell -ExecutionPolicy Bypass -File .\ENTIDP-RiskHunt.ps1 -WorkspaceId "<LA workspace GUID>" (requires the Az.OperationalInsights module and reader access to the workspace) Graph mode: powershell -ExecutionPolicy Bypass -File .\ENTIDP-RiskHunt.ps1 (Microsoft Graph SDK; read-only: IdentityRiskEvent.Read.All, AuditLog.Read.All) EXPECTED RESULTS A list of recent medium/high-risk sign-ins and risk detections (and, in KQL mode, CAE/token signals). Read-only — no changes are made. Verify sign-in/risk log export exists for KQL mode. .NOTES White-label — Entra ID Solutions. Read-only. KQL requires SignInLogs/RiskyUsers/UserRiskEvents exported. > [CmdletBinding()] param([string]$WorkspaceId, [int]$Days = 7)

How to run: KQL mode: powershell -ExecutionPolicy Bypass -File .\ENTIDP-RiskHunt.ps1 -WorkspaceId "<LA workspace GUID>" (requires the Az.OperationalInsights module and reader access to the workspace) Graph mode: powershell -ExecutionPolicy Bypass -File .\ENTIDP-RiskHunt.ps1 (Microsoft Graph SDK; read-only: IdentityRiskEvent.Read.All, AuditLog.Read.All) EXPECTED RESULTS A list of recent medium/high-risk sign-ins and risk detections (and, in KQL mode, CAE/token signals). Read-only — no changes are made. Verify sign-in/risk log export exists for KQL mode. .NOTES White-label — Entra ID Solutions. Read-only. KQL requires SignInLogs/RiskyUsers/UserRiskEvents exported. > [CmdletBinding()] param([string]$WorkspaceId, [int]$Days = 7)

ENTIDP-Set-PolicyState.ps1

Purpose: Performs the staged-enforcement (and rollback) step: moves a single, named Conditional Access policy from report-only to enabled — or back to report-only — after the report-only results are clean. Runs in -WhatIf (preview) mode by default. As a safety guard it refuses to enable any policy that does NOT exclude the named break-glass group, so a flip can never lock out break-glass accounts. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTIDP-Set-PolicyState.ps1 `-PolicyName "CA – Sign-In Risk – Pilot (Report-Only)" -TargetState enabled` -BreakGlassGroupName "CA Break-Glass Exclusion" Apply: add -WhatIf:$false to the same command after reviewing the preview. Rollback: set -TargetState reportOnly to move a policy back to report-only. Requires the Microsoft Graph PowerShell SDK. Scope: Policy.ReadWrite.ConditionalAccess, Group.Read.All. EXPECTED RESULTS A preview (or applied change) of the single policy's state; the break-glass guard blocks enabling any policy that does not exclude break-glass. Re-run ENTIDP-Validate.ps1 afterward. .NOTES White-label — Entra ID Solutions. Changes a Conditional Access policy state — preview first, one policy at a time. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string]$PolicyName,

[Parameter(Mandatory=$true)][ValidateSet('enabled','reportOnly')][string]$TargetState, [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.ReadWrite.ConditionalAccess','Group.Read.All' -NoWelcome Write-Host "=== ENTIDP Set-PolicyState — '$PolicyName' -> $TargetState ===" -ForegroundColor Cyan

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\ENTIDP-Set-PolicyState.ps1 `-PolicyName "CA – Sign-In Risk – Pilot (Report-Only)" -TargetState enabled` -BreakGlassGroupName "CA Break-Glass Exclusion" Apply: add -WhatIf:$false to the same command after reviewing the preview. Rollback: set -TargetState reportOnly to move a policy back to report-only. Requires the Microsoft Graph PowerShell SDK. Scope: Policy.ReadWrite.ConditionalAccess, Group.Read.All. EXPECTED RESULTS A preview (or applied change) of the single policy's state; the break-glass guard blocks enabling any policy that does not exclude break-glass. Re-run ENTIDP-Validate.ps1 afterward. .NOTES White-label — Entra ID Solutions. Changes a Conditional Access policy state — preview first, one policy at a time. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string]$PolicyName, [Parameter(Mandatory=$true)][ValidateSet('enabled','reportOnly')][string]$TargetState, [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.ReadWrite.ConditionalAccess','Group.Read.All' -NoWelcome Write-Host "=== ENTIDP Set-PolicyState — '$PolicyName' -> $TargetState ===" -ForegroundColor Cyan

ENTIDP-Validate.ps1

Purpose: Validates the pilot state before enforcement: the four named Conditional Access policies exist, are in report-only, target the pilot scope group, and exclude the break-glass group. Also flags whether token-protection session control and authentication strengths are wired as expected. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTIDP-Validate.ps1 `-PilotGroupName "IDP Pilot – Risk Scope – Pilot"` -BreakGlassGroupName "CA Break-Glass Exclusion" Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, Group.Read.All. EXPECTED RESULTS PASS/WARN per policy: exists, report-only, pilot scoped, break-glass excluded. Any WARN is a gate failure to fix before flipping to enforcement. .NOTES White-label — Entra ID Solutions. Read-only against Graph. > [CmdletBinding()] param([string]$PilotGroupName = 'IDP Pilot – Risk Scope – Pilot', [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Scopes 'Policy.Read.All','Group.Read.All' -NoWelcome Write-Host "`n=== ENTIDP — pilot validation ===" -ForegroundColor Cyan

How to run: powershell -ExecutionPolicy Bypass -File .\ENTIDP-Validate.ps1 `-PilotGroupName "IDP Pilot – Risk Scope – Pilot"` -BreakGlassGroupName "CA Break-Glass Exclusion" Requires the Microsoft Graph PowerShell SDK. Read-only scopes: Policy.Read.All, Group.Read.All. EXPECTED RESULTS PASS/WARN per policy: exists, report-only, pilot scoped, break-glass excluded. Any WARN is a gate failure to fix before flipping to enforcement. .NOTES White-label — Entra ID Solutions. Read-only against Graph. > [CmdletBinding()] param([string]$PilotGroupName = 'IDP Pilot – Risk Scope – Pilot', [string]$BreakGlassGroupName = 'CA Break-Glass Exclusion') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force

```
-AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph
-Scopes 'Policy.Read.All','Group.Read.All' -NoWelcome Write-Host "`n=== ENTIDP — pilot validation ==="
-ForegroundColor Cyan
```